

Sample Lending Security Review

Table of Contents

[C-01] Unchecked collateral withdrawal can drain reserves	8
[H-01] Liquidation accounting can double-count repaid debt	12
[M-01] Oracle heartbeat is not enforced	16
[L-01] Event omits recipient for queued withdrawals	20
[I-01] NatSpec uses stale parameter names	24

Findings

[C-01] Unchecked collateral withdrawal can drain reserves

Context: LendingPool.sol#L88

Description: The withdrawCollateral path transfers collateral before reducing the borrower balance, allowing a reentrant reserve drain.

Recommendation: Update collateral accounting before external transfers.

Resolution: Fixed

[H-01] Liquidation accounting can double-count repaid debt

Context: Liquidator.sol#L144

Description: Liquidation settlement applies repaid debt to both the isolated bucket and the global debt accumulator.

Recommendation: Apply the debt delta exactly once and assert accumulator parity.

Resolution: Acknowledged

[M-01] Oracle heartbeat is not enforced

Context: PriceOracle.sol#L52

Description: The price reader accepts stale oracle rounds after heartbeat expiry.

Recommendation: Reject prices older than the configured heartbeat.

Resolution: Fixed

[L-01] Event omits recipient for queued withdrawals

Context: WithdrawalQueue.sol#L31

Description: The queued withdrawal event omits the recipient address.

Recommendation: Include the recipient in the emitted event.

Resolution: Acknowledged

[I-01] NatSpec uses stale parameter names

Context: VaultDocs.sol#L12

Description: The NatSpec comment references the previous receiver parameter name.

Recommendation: Update the comment to match the current function signature.

Resolution: Fixed